

PES UNIVERSITY, BENGALURU

Department of Computer Science and Engineering

SOFTWARE TEST PLAN (STP)

ONLINE BOOKSTORE

Project Information	Details
Project	Online Bookstore
Version	1.1 – Final (synchronized with SRS v1.1 Final, SAD v1.1, Security & Integration Plan v1.1)
Authors	Team 2 – Member 3 (Testing)
Date	October 2026
Status	Final

Revision note (v1.1 Final): added TC-25 (logout), TC-26 (view cart) and TC-27 (duplicate add-to-cart) and the matching RTM rows required by SRS Appendix C; replaced the provisional PSC-01 to PSC-19 controls with SEC-CTRL-01 to SEC-CTRL-20 as used in the SRS and SAD; removed all “open/proposed” statements that SRS v1.1 Final has resolved; corrected integration scenario IT-02; removed Appendix A (it embedded the SAD v1.0 draft pages mislabelled as the SRS); restarted numbered lists.

Contents

- 1 Introduction
- 2 Test Items
- 3 Features to Be Tested
- 4 Features Not to Be Tested
- 5 Test Approach / Strategy
- 6 Test Environment
- 7 Test Schedule
- 8 Test Deliverables
- 9 Roles and Responsibilities
- 10 Risks and Mitigation
- 11 Assumptions & Dependencies
- 12 Suspension & Resumption Criteria
- 13 Test Case Management & Traceability
- 14 Test Metrics & Reporting
- 15 Approvals
- 16 Architecture, Design and Security Synchronization
- 17 Final Traceability Synchronization

1 Introduction

1.1 Purpose

The purpose of this Software Test Plan (STP) is to define the testing strategy, scope, objectives, resources, schedule, responsibilities and procedures for testing the Online Bookstore web application. The plan ensures that the application meets the functional, non-functional and security requirements specified in the Software Requirements Specification (SRS) v1.1 Final. The testing process will help identify defects, verify system functionality, validate security requirements and ensure that the application behaves as expected.

1.2 Scope

The scope of testing includes the following functionalities of the Online Bookstore:

- User registration, login and logout.
- Browsing and searching for books.
- Adding book listings by authenticated sellers.
- Adding books to, removing books from, and viewing the shopping cart.
- Placing orders.
- Viewing previously placed orders.
- Performance testing of book search.
- Usability testing of major operations.
- Reliability and data consistency testing.
- Browser compatibility testing.
- Role-based access control testing.
- Protection of user data and verification of the detailed security controls SEC-CTRL-01 to SEC-CTRL-20.

The application is developed using Python Django, with SQLite for development and demonstration and PostgreSQL if hosted (SRS 2.1).

1.3 References

- Software Requirements Specification (SRS) – Online Bookstore, Version 1.1 Final, Team 2.
- Software Architecture and Design Specification – Online Bookstore, Version 1.1.
- Online Bookstore – Security & Integration Plan (M4), Version 1.1.
- Project guidelines provided by the faculty.
- Software Test Plan template and sample provided for the project.

1.4 Definitions and Acronyms

Term	Definition
STP	Software Test Plan.
SRS	Software Requirements Specification.
SAD	Software Architecture and Design Specification.
RTM	Requirements Traceability Matrix.
FR / NFR	Functional / Non-Functional Requirement.
SEC	Security Requirement (SEC-01, SEC-02).
SEC-CTRL	Detailed security control supporting SEC-01 or SEC-02.

Term	Definition
SO	Security Objective.
TC	Test Case.
IT	Integration Test scenario.
UI	User Interface.
UAT	User Acceptance Testing.
Django	Python-based web development framework.

2 Test Items

The following components of the Online Bookstore application will be considered for testing:

1. User registration module.
2. User login, logout and authentication module.
3. Book browsing module.
4. Book search module.
5. Seller book listing module.
6. Shopping cart module (add, remove, view).
7. Order placement module.
8. Order history module.
9. Role-based access control.
10. User data protection and detailed security controls.
11. Search performance.
12. Application navigation and usability.
13. Data consistency.
14. Browser compatibility.
15. Software modularity and testability.

3 Features to Be Tested

3.1 Functional Features

ID	Feature	Verification
FT-01	User Registration (FR-AUTH-01)	A new user can register with Name, Email, Password and Role (Customer or Seller); incomplete or invalid registration is rejected.
FT-02	User Login (FR-AUTH-02)	Registered users can log in with valid credentials; invalid credentials are rejected with one generic message.
FT-03	Book Browsing (FR-BOOK-01)	Users can browse the available books (paginated).
FT-04	Book Search (FR-BOOK-02)	Users can search by title or author (case-insensitive partial match, maximum 100 characters); a no-results message is shown when nothing matches.
FT-05	Seller Book Listing (FR-BOOK-03)	Authenticated sellers can add listings with valid information; the creating Seller is recorded.
FT-06	Shopping Cart (FR-CART-01, FR-CART-02)	Authenticated customers can add books (quantity 1 to 10; an existing book increases the existing line) and remove books from their own cart.

ID	Feature	Verification
FT-07	Order Placement (FR-ORDER-01)	Authenticated customers can place orders containing the books in their cart.
FT-08	Order History (FR-ORDER-02)	Authenticated customers can view their own previously placed orders.
FT-09	User Logout (FR-AUTH-03)	Authenticated users can log out; the session is destroyed and cannot be reused.
FT-10	View Cart (FR-CART-03)	Authenticated customers can view their own cart with line items, line totals and cart total; an empty-cart message is shown when empty.

3.2 Non-Functional Features

ID	Feature	Verification
NFT-01	Performance (NFR-01)	Search results are displayed within 3 seconds under normal operating conditions (up to 10,000 listings and 50 concurrent users in the agreed test environment).
NFT-02	Usability (NFR-02)	Login, book search, cart operations and order placement can be completed using clear and consistent navigation within three clicks of the home page.
NFT-03	Reliability (NFR-03)	Cart and order data remain consistent after completed operations; a forced failure leaves no partial order.
NFT-04	Availability (NFR-04)	At least 99% of scheduled operating time, excluding planned maintenance, over an agreed monitoring period.
NFT-05	Compatibility (NFR-05)	Latest stable versions of Google Chrome, Mozilla Firefox and Microsoft Edge.
NFT-06	Maintainability (NFR-06)	Review of the modular structure and controlled changes show that a change to one major area does not affect unrelated areas.
NFT-07	Testability (NFR-07)	Each functional requirement can be tested independently through defined test cases.

3.3 Security Features

- **SEC-01 – Role-Based Access Control:** users can access only those functions permitted by their assigned roles (RBAC matrix, Section 16.3).
- **SEC-02 – Protection of User Data:** user data is protected from unauthorized access and disclosure.
- **SEC-CTRL-01 to SEC-CTRL-20:** detailed controls, verified in Section 16.2. SEC-CTRL-16 (login throttling) is an optional recommended enhancement; it is verified only if implemented and is not part of the mandatory acceptance baseline.

4 Features Not to Be Tested

The following items are outside the scope of testing for the current project version because they are outside the SRS scope (SRS 1.2):

1. Features not specified in the SRS, including editing or deleting listings, administrator dashboards, reviews, wishlists and discounts.
2. Third-party services and external systems that are not part of the project implementation.
3. Payment gateway processing (payment is out of scope; placing an order only records the order).
4. Delivery tracking and courier integration.
5. Mobile application functionality, because the current scope is a web application.

6. Performance under extreme load conditions beyond the agreed test environment and requirements.
7. Production deployment and infrastructure testing, unless a hosted environment is chosen; SEC-CTRL-17 is verified only in a hosted environment.

Any change to these exclusions must be approved by the project team and reflected in the SRS and this test plan.

5 Test Approach / Strategy

The testing approach executes planned test cases against the implemented Online Bookstore application and compares actual results with expected results.

5.1 Test Levels

- **Unit Testing:** individual functions and components such as registration validation, book search, cart operations and order processing.
- **Integration Testing:** interactions between modules (IT-01 to IT-06, Section 16.4).
- **System Testing:** the complete application against SRS v1.1 Final.
- **User Acceptance Testing (UAT):** main user workflows reviewed against expected user requirements, if included in the project schedule.

5.2 Test Types

- Functional, Positive and Negative Testing.
- Integration Testing.
- Performance Testing: book search response time.
- Usability Testing: clarity and consistency of navigation.
- Compatibility Testing: supported browsers.
- Security Testing: access restrictions, protection of user data and the SEC-CTRL controls.
- Regression Testing: rechecks existing functionality after code changes.
- Data Consistency Testing: cart and order data after operations.

5.3 Entry Criteria

1. The relevant requirements are documented in the SRS v1.1 Final.
2. The features selected for testing are implemented or available in a testable version.
3. The test environment is configured.
4. Required test data and test accounts are available.
5. Test cases have been prepared and reviewed.
6. The application can be accessed without blocking setup issues.

5.4 Exit Criteria

1. All planned test cases for the selected scope have been executed.
2. Actual results have been recorded.
3. Critical defects have been resolved or formally documented.
4. Failed test cases have been reported and reviewed.
5. Requirements have been mapped to their test cases.
6. A test summary has been prepared.

7. Remaining defects and limitations have been communicated to the project team.

5.5 Security Validation

Security validation verifies SEC-01, SEC-02 and the detailed controls SEC-CTRL-01 to SEC-CTRL-20 approved in SRS Section 3.5.4. The planned checks are:

1. Verify that users cannot access seller-only functions without the Seller role, and that a Seller cannot perform customer purchasing operations.
2. Verify that authenticated customers cannot access another customer's cart items or order history.
3. Verify that protected information is not disclosed to unauthorized users.
4. Verify that restricted pages and actions enforce authentication and authorization (every denied cell of the RBAC matrix).
5. Execute the SEC-CTRL verification table (Section 16.2) and record the results in the Security Test Record.
6. Record any security-related defects and report them to the development team.

6 Test Environment

6.1 Hardware Requirements

- Laptop or desktop computer.
- Minimum 4 GB RAM, preferably 8 GB or more.
- Sufficient storage for the application, database and test data.
- Stable internet connection if required by the development or test setup.

6.2 Software Requirements

- Operating System: Windows or another supported development operating system.
- Programming Language: Python.
- Web Framework: Django.
- Database: SQLite for development and demonstration; PostgreSQL if hosted.
- Web Browsers: latest stable versions of Google Chrome, Mozilla Firefox and Microsoft Edge.
- Code Editor: Visual Studio Code or another editor used by the team.
- Testing Environment: local development server or an agreed test server.

6.3 Testing Tools

- Django testing framework or Python unittest for automated tests.
- Browser developer tools for inspecting application behaviour.
- Manual test case sheets for recording test results.
- Spreadsheet or document tools for maintaining the RTM.
- Browser-based testing for compatibility checks.
- Timing tools or automated scripts for measuring search response time.
- `python manage.py check --deploy` for hosted-environment settings (SEC-CTRL-17).

6.4 Test Data

1. Valid user registration details.
2. Invalid or incomplete registration details.

3. Valid login credentials.
4. Invalid login credentials.
5. Sample book information for browsing and searching (including titles with HTML/script text for SEC-CTRL-13).
6. Seller test accounts.
7. Customer test accounts.
8. Available books for cart and order testing.
9. Accounts with previously placed orders.
10. Data for checking unauthorized access and data isolation.

Only dummy accounts and non-sensitive test information are used during testing.

7 Test Schedule

The following schedule is tentative and will be adjusted according to implementation progress and faculty instructions.

Milestone	Planned Activity	Tentative Date
M1	Review the SRS and identify testable requirements	2 October 2026
M2	Prepare the Software Test Plan	2–3 October 2026
M3	Prepare test cases and Requirements Traceability Matrix	3–4 October 2026
M4	Set up test environment and test data	4 October 2026
M5	Execute available functional test cases	5 October 2026
M6	Perform available integration, compatibility and security checks	5–6 October 2026
M7	Record defects and prepare test summary	6 October 2026
M8	Review and submit the testing documentation	By 7 October 2026

The schedule depends on the availability of implemented features. Tests that cannot be executed because a feature is not yet available are marked Not Executed or Blocked, as appropriate.

8 Test Deliverables

1. **Software Test Plan (STP):** testing scope, approach, resources, schedule and responsibilities.
2. **Test Case Document:** test case IDs, requirements, preconditions, steps, expected results, actual results and execution status.
3. **Requirements Traceability Matrix (RTM):** maps each requirement to its test cases.
4. **Test Execution Record:** execution status and results.
5. **Defect Report:** description, severity and status of defects.
6. **Test Summary Report:** tests performed, results, unresolved defects and limitations.
7. **Security Test Record:** security checks performed against SEC-01, SEC-02 and SEC-CTRL-01 to 20.

Only documents and results actually prepared or produced will be submitted as completed deliverables.

9 Roles and Responsibilities

Role	Name	Responsibility
Member 1 – SRS	Pooja Avadhani	Prepare and maintain the Software Requirements Specification.

Role	Name	Responsibility
Member 2 – Architecture/Design	Rahul M S	Prepare the Software Architecture and Design documentation.
Member 3 – Testing	Preksha B	Prepare the Software Test Plan, test cases, test execution records, RTM and testing documentation.
Member 4 – Integration/Traceability/Security	Ojas Binjola	Handle integration and traceability work and maintain the security objectives, controls and Security & Integration Plan.
All Team Members	Team 2	Review requirements, support defect resolution and coordinate project activities.

10 Risks and Mitigation

Risk	Mitigation
Delay in implementation of application features	Prepare test cases in advance and execute them when the relevant features become available.
Changes to requirements	The SRS v1.1 Final is the baseline; update test cases only when a change is approved in the SRS.
Insufficient test data	Prepare valid, invalid and boundary test data before execution.
Integration issues between modules	Perform integration testing (IT-01 to IT-06) after the relevant modules are connected.
Security or authorization defects	Test role-based access restrictions, ownership isolation and unauthorized access scenarios.
Browser-specific issues	Execute important workflows in the specified browsers.
Defects discovered close to the submission date	Prioritize critical defects and document unresolved issues clearly.
Limited time for test execution	Prioritize essential functional requirements, security requirements and required non-functional checks.
Test environment or database failure	Verify the environment before execution and maintain suitable test data backups.

11 Assumptions & Dependencies

1. The approved SRS v1.1 Final is available to the testing team and defines the expected behaviour of each feature.
2. The development team provides a testable version of the Online Bookstore application.
3. The application is developed using Python Django.
4. SQLite is used for development and demonstration; PostgreSQL if hosted. The hosting environment is chosen by the team.
5. User roles and permissions follow SRS Section 3.5.5.
6. Sample book data and test accounts are available for testing.
7. The test environment remains available during the planned testing period.
8. Performance and availability tests require an agreed test environment and measurement period.
9. SEC-CTRL-01 to SEC-CTRL-20 are approved in the SRS and are tested as defined in Section 16.2; SEC-CTRL-16 is tested only if implemented.

If any of these assumptions changes, the test plan and associated test cases may need to be updated.

12 Suspension & Resumption Criteria

12.1 Suspension Criteria

1. The application is unavailable or cannot be started.
2. A major defect prevents further testing of the affected feature.
3. The test environment or database is not functioning correctly.
4. Required test data or user accounts are unavailable.
5. A major requirement or interface change makes the existing test cases invalid.
6. A security issue requires the affected test activity to stop until it can be reviewed.

12.2 Resumption Criteria

1. The blocking defect has been resolved or an approved workaround is available.
2. The application and test environment are functioning correctly.
3. Required test data and accounts are available.
4. Updated requirements and test cases are available, if applicable.
5. The affected functionality has been verified sufficiently to continue testing.

Test cases affected by the suspension are re-executed where necessary and their results recorded.

13 Test Case Management & Traceability

Test cases are assigned unique IDs (TC-01 to TC-27) and mapped to the requirements in the SRS. The test case document contains the test case ID, requirement ID, description, preconditions, test steps, test data, expected result, actual result and execution status.

13.1 Test Case Identification

Test Case ID	Requirement ID	Test Scenario	Expected Result
TC-01	FR-AUTH-01	Register with valid required information (Name, Email, Password, Role)	Account is created successfully.
TC-02	FR-AUTH-01	Register with missing required information	Registration is rejected, no account is created and field-level validation feedback is displayed.
TC-03	FR-AUTH-02	Log in using valid credentials	User is authenticated successfully and a new session is created.
TC-04	FR-AUTH-02	Log in using an incorrect password	Login is rejected with one generic failure message.
TC-05	FR-BOOK-01	Browse available books	Available books are displayed with title, author and price.
TC-06	FR-BOOK-02	Search for a book that exists	Matching books are displayed.
TC-07	FR-BOOK-02	Search for a book with no matching results	A “no results” message is displayed.
TC-08	FR-BOOK-03	Authenticated seller adds a book with valid information	The book listing is validated and stored, recording the creating Seller.
TC-09	FR-BOOK-03, SEC-01	User without seller permission (Customer, or Anonymous Visitor) attempts to add a book	Customer receives HTTP 403; Anonymous Visitor is redirected to login; no listing is created.
TC-10	FR-CART-01	Customer adds an available book to the cart	The selected book appears in the cart.
TC-11	FR-CART-02	Customer removes a book from the cart	The selected book is removed from the cart.

Test Case ID	Requirement ID	Test Scenario	Expected Result
TC-12	FR-ORDER-01	Customer places an order with a valid, non-empty cart	The order is created with status "Placed" and the cart is cleared.
TC-13	FR-ORDER-01	Customer attempts to place an order with an empty cart	No order is created and an explanatory message is displayed.
TC-14	FR-ORDER-02	Customer views their order history	Previously placed orders belonging to that customer are displayed, most recent first.
TC-15	FR-ORDER-02, SEC-02	Customer attempts to access another customer's order history	Access is denied (HTTP 404) and private order data is not disclosed.
TC-16	NFR-01	Measure book search response time under normal operating conditions	Search results are displayed within 3 seconds.
TC-17	NFR-02	Complete login, search, cart and order workflows	The workflows can be completed using clear and consistent navigation.
TC-18	NFR-03	Verify cart and order data after successful operations and after a forced order failure	Cart and order data remain consistent; no partial order exists after a failure.
TC-19	NFR-04	Measure application availability over an agreed monitoring period	Availability is at least 99% of scheduled operating time, excluding planned maintenance.
TC-20	NFR-05	Execute key workflows in supported browsers	The application works as expected in the latest stable Chrome, Firefox and Edge.
TC-21	NFR-06	Review modularity and assess the effect of a controlled change	Changes to one major functional area do not affect unrelated areas.
TC-22	NFR-07	Review the test case mapping for functional requirements	Each functional requirement has an independently executable test case.
TC-23	SEC-01	Attempt to access a restricted function without the required role	The restricted operation is denied (HTTP 403) and no data changes.
TC-24	SEC-02	Attempt unauthorized access to protected user data	Unauthorized access is denied and data is not disclosed.
TC-25	FR-AUTH-03	Customer or Seller logs out, then reuses the old session to access a protected page	The session is destroyed; the old session is treated as an Anonymous Visitor and the protected page redirects to login.
TC-26	FR-CART-03	Customer views the cart containing several books; then views an empty cart	Each line shows title, quantity, current unit price and line total with the correct cart total; an empty-cart message is shown when empty.
TC-27	FR-CART-01	Customer adds a book that is already in the cart; then attempts a quantity above 10	The quantity of the existing line increases; there is no duplicate cart line; a quantity above 10 is rejected, the cart is unchanged and an error is shown.

13.2 Requirements Traceability Matrix (RTM)

Requirement ID	Requirement Description	Test Case IDs
FR-AUTH-01	User registration	TC-01, TC-02
FR-AUTH-02	User login	TC-03, TC-04
FR-AUTH-03	User logout	TC-25
FR-BOOK-01	Browse books	TC-05
FR-BOOK-02	Search books	TC-06, TC-07
FR-BOOK-03	Seller adds a book listing	TC-08, TC-09
FR-CART-01	Add book to cart	TC-10, TC-27
FR-CART-02	Remove book from cart	TC-11

Requirement ID	Requirement Description	Test Case IDs
FR-CART-03	View cart	TC-26
FR-ORDER-01	Place an order	TC-12, TC-13
FR-ORDER-02	View order history	TC-14, TC-15
NFR-01	Search performance	TC-16
NFR-02	Usability	TC-17
NFR-03	Reliability and data consistency	TC-18
NFR-04	Availability	TC-19
NFR-05	Browser compatibility	TC-20
NFR-06	Maintainability	TC-21
NFR-07	Testability	TC-22
SEC-01	Role-based access control	TC-09, TC-23
SEC-02	Protection of user data	TC-15, TC-24

The RTM is identical to SRS Appendix C.1. Test cases are planned scenarios; actual results and status are recorded only after the tests are performed. The SEC-CTRL controls are traced in Section 16.2.

14 Test Metrics & Reporting

14.1 Test Execution Metrics

- **Total Test Cases:** total planned for the selected scope (TC-01 to TC-27 plus the SEC-CTRL checks and IT-01 to IT-06).
- **Executed / Passed / Failed:** counts of executed test cases and their outcomes against expected results.
- **Blocked:** cannot be executed because of an unavailable feature, environment problem or dependency.
- **Not Executed:** not yet executed.

14.2 Defect Metrics

For each defect record: defect ID; description; related requirement and test case; severity and priority; date reported; assigned team member; current status; resolution and retest result.

14.3 Reporting

Progress and results are documented in the test execution record. Defects are communicated to the relevant development team members. A test summary is prepared at the end of the testing cycle. No execution statistics or defect counts are reported as actual results until execution data is available.

15 Approvals

Role	Name	Signature / Approval	Date
Testing Team Member	Preksha B.	_____	_____
Team Leader	[Name]	_____	_____
Project Guide / Faculty	[Name]	_____	_____

16 Architecture, Design and Security Synchronization

This section synchronizes the STP with SRS v1.1 Final and SAD v1.1. The SRS is the authoritative acceptance baseline; the SAD is design guidance consistent with it.

Area	Baseline	STP treatment
Framework	Python Django (SRS 2.4).	Test environment and strategy use Django.
Architecture	Layered modular monolith (SAD 3.5).	Maintainability and integration tests verify module boundaries and cross-module behaviour.
Database	SQLite for development and demonstration; PostgreSQL if hosted (SRS 2.1).	Tests run on SQLite; migrations are re-run on PostgreSQL if a hosted environment is chosen.
Deployment	Not yet chosen (SRS Appendix D, only open item).	Local/test-server testing is in scope; hosted-environment checks (SEC-CTRL-17) are conditional.
Roles	Anonymous Visitor, Customer, Seller. Role chosen at registration, validated by the server, not changeable (FR-AUTH-01, BR-04).	RBAC tests cover all three; registration tests include valid and tampered Role values (SEC-CTRL-07).
Seller purchasing	Not permitted (BR-03).	Seller attempts at cart/order operations must return 403.
Security	SO-1 to SO-6; SEC-CTRL-01 to 20 (SRS 3.5).	Verified in Section 16.2.
Order integrity	Server-calculated prices; one transaction for order creation (SEC-CTRL-09, 11).	Integration tests cover price tampering and atomic success/failure.
Browser routes	Routes in SRS 3.5.5 / SAD 4.3 are indicative.	Tests target behaviour, not exact URL names.
Payment	Out of scope (BR-07).	Payment testing is out of scope.

16.1 SRS vs SAD vs STP Consistency Rules

- SRS requirements are the authoritative acceptance baseline. SAD design choices are implementation guidance unless stated in the SRS.
- The SRS top-level security requirements are SEC-01 and SEC-02. The detailed controls are SEC-CTRL-01 to SEC-CTRL-20 and are used with the same identifiers in the SRS, SAD, STP and Security & Integration Plan.
- SEC-CTRL-16 is optional; its absence is not a failed acceptance criterion.
- The only open item is the deployment environment; no test case depends on it except hosted-environment checks.

16.2 Security Control Verification (SEC-CTRL-01 to SEC-CTRL-20)

Control ID	Control (SRS 3.5.4)	Verification	Related TC
SEC-CTRL-01	Salted password hashes	Inspect the stored credential; no plaintext; Django hasher format.	–
SEC-CTRL-02	Password validators	Register with a weak password (too short, common, all-numeric); each is rejected.	TC-02
SEC-CTRL-03	Generic login failure	Compare responses for unknown email and wrong password; they are identical.	TC-04
SEC-CTRL-04	Session lifecycle	Session key changes at login; the old session is invalid after logout.	TC-03, TC-25
SEC-CTRL-05	Authentication on protected routes	Anonymous request to each protected route redirects to login.	TC-09, TC-23
SEC-CTRL-06	Server-side RBAC	Customer requests /books/add/; Seller requests /cart/add/; both receive 403 with no data change.	TC-09, TC-23

Control ID	Control (SRS 3.5.4)	Verification	Related TC
SEC-CTRL-07	Server-side role assignment	Tamper with the Role POST value (e.g. admin/staff) at registration; it is rejected.	TC-01, TC-02
SEC-CTRL-08	Ownership scoping	User A requests user B's cart item or order; HTTP 404 and no data change.	TC-15, TC-24
SEC-CTRL-09	Server-side price/total	POST a tampered price/total; the stored order amount is unchanged.	TC-12
SEC-CTRL-10	Quantity validation	Quantity 0, -1, 11, 99999 and "abc" are rejected and the cart is unchanged.	TC-27
SEC-CTRL-11	Atomic order creation	Force a failure mid-order; no Order/OrderItem exists and the cart is intact.	TC-18
SEC-CTRL-12	CSRF	POST without a valid CSRF token is rejected (403).	–
SEC-CTRL-13	Output escaping	Submit <script> in a listing title/description and in search text; it is displayed as text.	TC-08, TC-06
SEC-CTRL-14	ORM-only access	Code review/grep for raw(and execute(; malicious input in search/forms causes no error or leak.	–
SEC-CTRL-15	Bounded search	A query over 100 characters is rejected; results are paginated at 20 per page.	TC-06, TC-16
SEC-CTRL-16	Login throttling (optional)	If implemented: script 6 consecutive bad logins; the account is temporarily locked out. Otherwise Not Applicable.	–
SEC-CTRL-17	Hosted security settings	In a hosted environment: DEBUG=False, HTTPS, secure/HttpOnly cookies, HSTS, secrets from environment; check --deploy passes.	–
SEC-CTRL-18	Safe logging	Log review: failed login, denied access and failed order events are logged with user ID and timestamp; no passwords, session IDs, keys or tokens.	–
SEC-CTRL-19	Generic error pages	Trigger a 404 and a 500; no stack trace or internal detail is shown.	–
SEC-CTRL-20	Safe post-login redirect	Log in with ?next=https://evil.com; the external address is ignored.	–

16.3 RBAC Authorization Matrix

Operation	Anonymous Visitor	Customer	Seller
Register	Allowed	Not Allowed	Not Allowed
Login	Allowed	Allowed	Allowed
Logout	Not Allowed	Allowed	Allowed
Browse / Search	Allowed	Allowed	Allowed
Add book listing	Login required	403 Denied	Allowed
View cart	Login required	Own cart only	403 Denied
Add / remove cart item	Login required	Own cart only	403 Denied
Place order	Login required	Own cart only	403 Denied
View order history	Login required	Own orders only	403 Denied

This matrix is identical to SRS Section 3.5.5. One test per denied cell proves the denial. Sellers cannot purchase (BR-03).

16.4 Integration Tests

ID	Integration Scenario	Expected Result
IT-01	Seller creates a listing; Customer searches for the book.	Book is searchable and displayed with the stored listing information.
IT-02	Customer adds a book to the cart; the stored price of that book is then changed through a maintenance or test-data update (Sellers cannot edit listings in this version); Customer places the order.	Order total and OrderItem unit price use the current stored price.
IT-03	Customer places an order; then views order history.	Order and OrderItems appear in the customer's history and the cart is empty.
IT-04	A failure occurs during multi-record order creation.	Transaction rolls back; no partial order data remains and the cart is intact.
IT-05	Customer A requests Customer B's cart item or order.	Access is denied (404) and no private data is disclosed.
IT-06	Session expires during a protected operation.	User is required to authenticate again and no unauthorized or partial state change occurs.

16.5 Decisions Resolved and Remaining Open Items

Item	Status
Database engine	Resolved: SQLite for development and demonstration; PostgreSQL if hosted.
Registration role selection	Resolved: Customer or Seller chosen at registration; not changeable.
Duplicate add-to-cart	Resolved: increases the existing line; unique (customer, book); maximum 10 (TC-27).
Seller purchasing	Resolved: not permitted (BR-03).
Security objectives and controls	Resolved: SO-1 to SO-6 and SEC-CTRL-01 to 20 approved in the SRS.
Payment processing	Out of scope.
Exact URL names	Routes are indicative; tests follow the implemented routes while preserving required behaviour.
Open: Deployment environment	Hosted deployment is not chosen; hosted-environment checks (SEC-CTRL-17, PostgreSQL migration) run only if a hosted environment is used.

17 Final Traceability Synchronization

The STP retains the SRS requirement identifiers and verifies the design-level controls with the SEC-CTRL identifiers defined in the SRS.

SRS Requirement	SAD Design / Control	STP Verification
FR-AUTH-01 / 02 / 03	Accounts/Authentication; session handling; /logout/	TC-01 to TC-04, TC-25; SEC-CTRL-01 to 04, 07, 20
FR-BOOK-01 / 02	Book Management; bounded search	TC-05 to TC-07, TC-16; SEC-CTRL-13, 15
FR-BOOK-03	Seller-only listing route; server-side RBAC; seller FK	TC-08, TC-09; SEC-CTRL-05, 06
FR-CART-01 / 02 / 03	Customer-scoped Cart Management	TC-10, TC-11, TC-26, TC-27; SEC-CTRL-08, 10
FR-ORDER-01	Order Management; transaction; server-side price	TC-12, TC-13, TC-18; SEC-CTRL-09, 11; IT-02 to IT-04
FR-ORDER-02	User-scoped order history	TC-14, TC-15; SEC-CTRL-08; IT-03, IT-05
NFR-01 to NFR-07	Search latency, UX, transactions, deployment, browser UI, modular design	TC-16 to TC-22

SRS Requirement	SAD Design / Control	STP Verification
SEC-01	Server-side RBAC (SAD 3.10.3)	TC-09, TC-23; SEC-CTRL-05, 06, 07
SEC-02	Authentication, ownership, CSRF, XSS, safe logging/errors	TC-15, TC-24; SEC-CTRL-01 to 04, 08 to 20

End of Software Test Plan